

Scenario 3 output 1 chatgpt

Threat 1 — Account Takeover Through Recovery Information Manipulation

- **Threat ID:** T1
- **Threat name:** Account Takeover Through Malicious Recovery Information
- **STRIDE category:** Elevation of Privilege / Spoofing
- **Affected component/data flow:** EE1 → P1 → P2; P2 → DS1
- **Attack scenario:** An attacker submits fabricated, manipulated, or stolen recovery information through P1. If P2's identity verification logic accepts insufficient or attacker-controlled evidence, the attacker may obtain recovery authorization for another user's account.
- **Impact:** Full account compromise, unauthorized access to the account, exposure of profile information, and subsequent unauthorized profile changes.
- **Severity:** Critical
- **Likelihood:** High
- **Mitigation:** P2 should enforce strong identity verification using multiple independent verification factors where defined by the recovery process. Recovery information must be validated server-side and treated as untrusted. Verification must be performed independently of P4 and P5. Implement attempt limits and monitoring for repeated failed recovery requests.
- **OWASP LLM Top 10 mapping:** LLM06 – Excessive Agency is not directly applicable to the core attack because the AI has no recovery authority. LLM01 – Prompt Injection may become relevant if malicious recovery information is exposed to P4/P5 and influences AI guidance.

Threat 2 — Identity Verification Bypass Through AI Guidance

- **Threat ID:** T2
- **Threat name:** AI-Assisted Identity Verification Bypass
- **STRIDE category:** Elevation of Privilege
- **Affected component/data flow:** EE1 → P1 → P4/P5; P4/P5 → EE1
- **Attack scenario:** An attacker asks P4 how to recover an account and attempts to obtain detailed guidance about recovery verification requirements. The attacker uses the information to construct recovery submissions specifically designed to bypass P2's verification checks.
- **Impact:** Increased probability of successful account takeover and disclosure of security-sensitive recovery procedures.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** P4 should provide general recovery guidance without revealing verification secrets, internal validation rules, token-generation logic, or information that would allow users to predict P2's acceptance criteria. P4 must never claim that a user has been authenticated or approved.

- **OWASP LLM Top 10 mapping:** LLM02 – Sensitive Information Disclosure, LLM01 – Prompt Injection.

Threat 3 — Recovery Token Leakage Through User Interaction

- **Threat ID:** T3
- **Threat name:** Recovery Token Disclosure
- **STRIDE category:** Information Disclosure
- **Affected component/data flow:** P2 → DS2 → P2 → P1 → EE1
- **Attack scenario:** A recovery token is exposed through an improperly handled frontend response, error message, recovery result, or other output path. An attacker who obtains the token can use it to attempt account recovery.
- **Impact:** Unauthorized account recovery and account takeover.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation:** Recovery tokens must be transmitted only through the intended recovery mechanism. P1 should not expose tokens unnecessarily. Tokens should never be sent to P4, P5, or EE2. Error messages should not reveal token values or sensitive token metadata. P2 should validate every token server-side.
- **OWASP LLM Top 10 mapping:** LLM02 – Sensitive Information Disclosure where AI-related processing is involved. The core token leakage path is primarily a traditional application-security threat.

Threat 4 — Recovery Token Replay

- **Threat ID:** T4
- **Threat name:** Recovery Token Replay
- **STRIDE category:** Elevation of Privilege
- **Affected component/data flow:** EE1 → P1 → P2 → DS2
- **Attack scenario:** An attacker obtains a previously valid recovery token and submits it again after it has already been used. If P2 fails to enforce token consumption or invalidation state stored in DS2, the token may authorize another recovery operation.
- **Impact:** Repeated unauthorized account recovery and persistent account takeover.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation:** P2 must check token expiration, validity, and consumption/invalidation state in DS2 for every use. Tokens must become unusable immediately after successful consumption. Token validation and invalidation should be performed atomically to prevent repeated use.
- **OWASP LLM Top 10 mapping:** No direct OWASP LLM Top 10 mapping. This is primarily a recovery-token lifecycle vulnerability.

Threat 5 — Recovery Token Brute Force or Guessing

- **Threat ID:** T5
- **Threat name:** Recovery Token Guessing
- **STRIDE category:** Elevation of Privilege
- **Affected component/data flow:** EE1 → P1 → P2 → DS2

- **Attack scenario:** An attacker repeatedly submits candidate recovery tokens to P2. If tokens have insufficient entropy or validation attempts are unlimited, the attacker may eventually discover a valid token.
- **Impact:** Unauthorized recovery and account takeover.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation:** Generate cryptographically strong, unpredictable tokens. P2 should enforce expiration, attempt limits, and appropriate throttling. Invalid token attempts should not reveal whether a token exists or is associated with a particular account.
- **OWASP LLM Top 10 mapping:** No direct OWASP LLM Top 10 mapping.

Threat 6 — Token Metadata Leakage

- **Threat ID:** T6
- **Threat name:** Recovery Token Metadata Disclosure
- **STRIDE category:** Information Disclosure
- **Affected component/data flow:** DS2 → P2 → P1 → EE1; P2/P5 context boundaries
- **Attack scenario:** Error messages or AI-generated responses indirectly disclose token expiration, token state, consumption status, or other recovery metadata. An attacker uses this information to narrow the token attack space or determine whether a recovery attempt is active.
- **Impact:** Facilitates token abuse and account takeover.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Return generic recovery errors. Do not expose internal token metadata to P4, P5, EE2, or unauthorized users. P2 should internally distinguish token states without unnecessarily revealing them externally.
- **OWASP LLM Top 10 mapping:** LLM02 – Sensitive Information Disclosure, LLM05 – Improper Output Handling.

Threat 7 — Unauthorized Profile Modification

- **Threat ID:** T7
- **Threat name:** Profile Modification Without Recovery Authorization
- **STRIDE category:** Elevation of Privilege / Tampering
- **Affected component/data flow:** P1 → P3; P2 → P3; P3 → DS1
- **Attack scenario:** An attacker submits a profile-update request through P1 without obtaining valid recovery authorization from P2. If P3 trusts the request or incorrectly interprets authorization state, it may modify DS1.
- **Impact:** Unauthorized modification of account information and possible account takeover.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation:** P3 must independently enforce the requirement that profile updates occur only after authorized recovery approval from P2. P3 must not accept authorization claims originating from P4, P5, or EE1. Authorization state should be validated server-side.
- **OWASP LLM Top 10 mapping:** LLM06 – Excessive Agency is relevant as a defense requirement: AI must never be treated as an authorization authority.

Threat 8 — AI Assistant Impersonating Recovery Authority

- **Threat ID:** T8
- **Threat name:** False AI Authorization
- **STRIDE category:** Spoofing / Elevation of Privilege
- **Affected component/data flow:** EE1 → P4 → P5 → EE2 → P5 → P4 → EE1
- **Attack scenario:** The external LLM produces a response such as "your identity has been verified" or "your recovery request has been approved." A user interprets the response as an actual authorization decision even though P2 has made no such decision.
- **Impact:** Users may disclose sensitive information, believe an account has been recovered, or attempt unauthorized operations based on false authorization.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Clearly constrain P4's role in system prompts and application logic. P4 must explicitly distinguish guidance from authorization. P1 should obtain actual recovery status from P2 rather than relying on AI-generated statements. External LLM output must never be treated as authoritative.
- **OWASP LLM Top 10 mapping:** LLM06 – Excessive Agency, LLM09 – Misinformation.

Threat 9 — Prompt Injection Through Malicious User Input

- **Threat ID:** T9
- **Threat name:** Recovery-Related Prompt Injection
- **STRIDE category:** Tampering
- **Affected component/data flow:** EE1 → P1 → P4/P5 → EE2
- **Attack scenario:** An attacker submits recovery-related text such as instructions designed to override the assistant's behavior, for example attempting to make the assistant reveal internal instructions, approved context, or sensitive recovery information.
- **Impact:** Manipulation of AI responses, sensitive-information disclosure, misleading recovery guidance, or circumvention of intended AI restrictions.
- **Severity:** High
- **Likelihood:** High
- **Mitigation:** Treat all user-provided text as untrusted. Use strict prompt separation between system instructions and user content. P5 should send only sanitized prompts and approved context. Do not place secrets or recovery authorization information into the LLM context. Validate AI responses before displaying them where appropriate.
- **OWASP LLM Top 10 mapping:** LLM01 – Prompt Injection.

Threat 10 — Indirect Prompt Injection Through Recovery Information

- **Threat ID:** T10
- **Threat name:** Malicious Instructions Embedded in Recovery Data
- **STRIDE category:** Tampering
- **Affected component/data flow:** EE1 → P1 → P2/P4; P4 → P5 → EE2
- **Attack scenario:** An attacker places malicious instructions inside recovery information submitted to the system. If that information is later incorporated into an AI prompt, the LLM may interpret attacker-controlled content as instructions rather than data.
- **Impact:** Manipulated AI responses, disclosure of approved context, or misleading recovery guidance.

- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Clearly delimit recovery information from instructions. Sanitize content before it reaches P5. Do not expose recovery verification information or secrets to the LLM. P2 should perform security-critical verification independently of any AI processing.
- **OWASP LLM Top 10 mapping:** LLM01 – Prompt Injection.

Threat 11 — Sensitive Account Information Disclosure to the LLM

- **Threat ID:** T11
- **Threat name:** Unauthorized Sensitive Context Transmission
- **STRIDE category:** Information Disclosure
- **Affected component/data flow:** P1/P2/P4 → P5 → EE2
- **Attack scenario:** P5 incorrectly includes account identity, profile information, recovery verification information, or other private account data in the context sent to EE2.
- **Impact:** Sensitive information leaves the application's security boundary and is exposed to the external LLM provider.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation:** Enforce strict data minimization in P5. Only sanitized prompts and explicitly authorization-approved context may be transmitted. Recovery tokens, identity verification secrets, and private account data must be technically excluded from LLM requests. Apply allowlisting rather than relying solely on prompt instructions.
- **OWASP LLM Top 10 mapping:** LLM02 – Sensitive Information Disclosure.

Threat 12 — Prompt Injection Causing Sensitive Information Disclosure

- **Threat ID:** T12
- **Threat name:** Prompt Injection-Induced Data Disclosure
- **STRIDE category:** Information Disclosure
- **Affected component/data flow:** EE1 → P4/P5 → EE2 → P5/P4 → EE1
- **Attack scenario:** A malicious user attempts to manipulate the assistant into revealing information contained in approved context or internal instructions. The LLM follows the injected instruction and returns information that should not be disclosed to the user.
- **Impact:** Disclosure of account-related information, internal instructions, or other sensitive context provided to the LLM.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Minimize context sent to the LLM. Do not include secrets or unnecessary private account data. Treat LLM output as untrusted and filter responses before presentation. Separate authorization decisions and sensitive data handling from the AI path.
- **OWASP LLM Top 10 mapping:** LLM01 – Prompt Injection, LLM02 – Sensitive Information Disclosure.

Threat 13 — Insecure Handling of External LLM Output

- **Threat ID:** T13
- **Threat name:** Improper Output Handling
- **STRIDE category:** Tampering / Elevation of Privilege
- **Affected component/data flow:** EE2 → P5 → P4 → P1 → EE1
- **Attack scenario:** The external LLM returns malicious, misleading, or manipulated content. P1 or P4 displays the response as trusted information, causing the user to follow unsafe recovery instructions or believe an unauthorized action occurred.
- **Impact:** Social engineering, incorrect recovery actions, disclosure of information, and potential account compromise.
- **Severity:** High
- **Likelihood:** High
- **Mitigation:** Treat all LLM output as untrusted. Validate and constrain output formats. Prevent AI responses from being interpreted as authorization decisions. Clearly communicate that P4 provides guidance only. P1 should independently retrieve actual account/recovery status from authoritative services.
- **OWASP LLM Top 10 mapping:** LLM05 – Improper Output Handling, LLM09 – Misinformation.

Threat 14 — Excessive AI Agency

- **Threat ID:** T14
- **Threat name:** AI Influence Over Security-Critical Operations
- **STRIDE category:** Elevation of Privilege
- **Affected component/data flow:** P4/P5 ↔ P1/P2/P3
- **Attack scenario:** A design or implementation error causes an AI response to be treated as authorization for recovery or profile modification. Although P4 is explicitly prohibited from performing these actions, another component may incorrectly trust its output.
- **Impact:** AI-generated content could indirectly trigger account recovery or unauthorized profile changes.
- **Severity:** Critical
- **Likelihood:** Low to Medium
- **Mitigation:** Maintain a hard architectural separation between P4/P5 and authorization decisions. P2 must remain the only recovery authorization authority. P3 must require authorization originating from P2. Never use an LLM response as an authorization token, approval signal, or security decision.
- **OWASP LLM Top 10 mapping:** LLM06 – Excessive Agency.

Threat 15 — Recovery Authorization State Tampering

- **Threat ID:** T15
- **Threat name:** Manipulation of Recovery Authorization
- **STRIDE category:** Tampering / Elevation of Privilege
- **Affected component/data flow:** P2 → P3; P2 → DS2; P3 → DS1
- **Attack scenario:** An attacker attempts to cause P3 to interpret a request as authorized even though P2 has not approved recovery. This could occur if authorization state is represented in attacker-controlled request data or insufficiently validated between P2 and P3.
- **Impact:** Unauthorized profile modification and account takeover.
- **Severity:** Critical
- **Likelihood:** Medium

- **Mitigation:** P3 must not trust authorization information supplied by EE1 or P1. Authorization must originate from P2 and be validated server-side. P2 should be the authoritative source for recovery authorization status.
- **OWASP LLM Top 10 mapping:** No direct OWASP LLM Top 10 mapping. LLM06 is relevant only if AI output is incorrectly accepted as authorization.

Threat 16 — Profile Information Disclosure Through AI Assistance

- **Threat ID:** T16
- **Threat name:** Unauthorized Profile Data Exposure
- **STRIDE category:** Information Disclosure
- **Affected component/data flow:** DS1 → P4/P5 → EE2 or P4 → P1 → EE1
- **Attack scenario:** A user asks the AI assistant questions designed to extract private profile information. If P5 supplies excessive approved context or P4 reveals information without sufficient authorization, profile information may be disclosed.
- **Impact:** Privacy violation, account information exposure, and potential support for further account takeover.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Apply strict context minimization. Only provide P4 with information required to answer the question. Do not expose private account data to EE2. User identity and authorization should be determined outside the AI assistant.
- **OWASP LLM Top 10 mapping:** LLM02 – Sensitive Information Disclosure.

Threat 17 — Recovery Information Leakage Through AI Responses

- **Threat ID:** T17
- **Threat name:** Disclosure of Recovery Verification Information
- **STRIDE category:** Information Disclosure
- **Affected component/data flow:** DS1 → P4/P5 → EE2 → P4 → EE1
- **Attack scenario:** Recovery verification information is included in AI context, and the LLM reproduces or summarizes it in response to an attacker-controlled question.
- **Impact:** Attackers obtain information that may help them pass P2's identity verification process.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation:** Recovery verification information must never be included in LLM prompts unless explicitly permitted by the architecture; the stated security boundary strongly indicates that such information should remain outside EE2. P5 should enforce a denylist/allowlist of data types before transmission.
- **OWASP LLM Top 10 mapping:** LLM02 – Sensitive Information Disclosure.

Threat 18 — External LLM Provider Compromise or Misuse

- **Threat ID:** T18
- **Threat name:** External LLM Data Security Risk

- **STRIDE category:** Information Disclosure / Tampering
- **Affected component/data flow:** P5 ↔ EE2
- **Attack scenario:** EE2 is outside application security control. An attacker compromises the external LLM provider, abuses its processing environment, or otherwise obtains access to information transmitted by P5.
- **Impact:** Disclosure or manipulation of information sent outside the application security boundary.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Minimize all information sent to EE2. Never transmit recovery tokens, identity verification secrets, or private account data. Send only sanitized prompts and authorization-approved context. Treat every response from EE2 as untrusted.
- **OWASP LLM Top 10 mapping:** LLM02 – Sensitive Information Disclosure, LLM03 – Supply Chain.

Threat 19 — LLM Supply-Chain Risk

- **Threat ID:** T19
- **Threat name:** Malicious or Compromised External LLM Behavior
- **STRIDE category:** Tampering / Information Disclosure
- **Affected component/data flow:** P5 ↔ EE2
- **Attack scenario:** The external LLM provider changes model behavior, produces compromised responses, or becomes subject to a supply-chain compromise. P4 then produces misleading recovery guidance based on the compromised output.
- **Impact:** Incorrect security guidance, sensitive information disclosure, social engineering, or disruption of account recovery.
- **Severity:** High
- **Likelihood:** Low to Medium
- **Mitigation:** Treat EE2 as untrusted. Do not allow external LLM output to make security decisions. Keep security-critical operations within P2 and P3. Limit the data and context exposed to EE2.
- **OWASP LLM Top 10 mapping:** LLM03 – Supply Chain, LLM09 – Misinformation.

Threat 20 — AI Hallucination Leading to Unsafe Recovery Guidance

- **Threat ID:** T20
- **Threat name:** Incorrect Recovery Guidance
- **STRIDE category:** Tampering / Elevation of Privilege
- **Affected component/data flow:** EE2 → P5 → P4 → P1 → EE1
- **Attack scenario:** The LLM generates incorrect instructions about account recovery, token usage, identity verification, or profile management. The user follows those instructions and may expose information or perform an unsafe action.
- **Impact:** Account compromise, failed recovery, disclosure of sensitive information, or user manipulation.
- **Severity:** Medium to High
- **Likelihood:** High

- **Mitigation:** Restrict P4 to well-defined guidance. Use authoritative application-provided information where possible. Do not allow the LLM to invent recovery procedures. Clearly distinguish AI guidance from actual system status and authorization.
- **OWASP LLM Top 10 mapping:** LLM09 – Misinformation.

Threat 21 — System Prompt or Internal Instruction Disclosure

- **Threat ID:** T21
- **Threat name:** AI Instruction Leakage
- **STRIDE category:** Information Disclosure
- **Affected component/data flow:** EE1 → P4/P5 → EE2 → P4 → EE1
- **Attack scenario:** An attacker asks P4 to reveal its system instructions, internal restrictions, sanitized prompt structure, or other internal guidance. Prompt injection techniques may cause the LLM to disclose information that should remain internal.
- **Impact:** Disclosure of AI security controls and information that may help attackers craft more effective prompt-injection attacks.
- **Severity:** Medium
- **Likelihood:** High
- **Mitigation:** Do not rely on system-prompt secrecy as a primary security control. Keep secrets and security-critical authorization information outside the LLM context. Detect and reject requests attempting to extract internal instructions.
- **OWASP LLM Top 10 mapping:** LLM01 – Prompt Injection, LLM07 – System Prompt Leakage.

Threat 22 — Recovery Enumeration Through Error Responses

- **Threat ID:** T22
- **Threat name:** Account or Recovery-State Enumeration
- **STRIDE category:** Information Disclosure
- **Affected component/data flow:** EE1 → P1 → P2 → P1 → EE1
- **Attack scenario:** An attacker submits recovery requests for different accounts and compares responses, timing, or error messages. Differences reveal whether an account exists, whether recovery information matches, or whether a recovery token is active.
- **Impact:** User/account enumeration and improved targeting for account takeover.
- **Severity:** Medium to High
- **Likelihood:** High
- **Mitigation:** Use consistent external responses for valid and invalid recovery requests. Avoid exposing whether a particular account exists or which verification stage failed. Apply rate limiting to recovery attempts.
- **OWASP LLM Top 10 mapping:** LLM02 – Sensitive Information Disclosure if the AI assistant exposes such information; otherwise primarily a traditional application-security threat.

Threat 23 — Denial of Service Through Excessive AI Requests

- **Threat ID:** T23

- **Threat name:** Unbounded AI Resource Consumption
- **STRIDE category:** Denial of Service
- **Affected component/data flow:** EE1 → P1 → P4 → P5 → EE2
- **Attack scenario:** An attacker repeatedly submits large or numerous account-support requests, causing excessive interaction with P4/P5 and EE2.
- **Impact:** Increased resource consumption, degraded availability of account-support functionality, and increased external LLM usage.
- **Severity:** Medium
- **Likelihood:** Medium
- **Mitigation:** Apply request-size limits, rate limiting, input validation, and reasonable limits on AI interactions. Do not allow unrestricted user input to create unlimited external LLM requests.
- **OWASP LLM Top 10 mapping:** LLM10 – Unbounded Consumption.

Threat 24 — Malicious User Input Causing Cross-Context Confusion

- **Threat ID:** T24
- **Threat name:** Context Boundary Confusion
- **STRIDE category:** Tampering / Information Disclosure
- **Affected component/data flow:** EE1 → P1 → P4 → P5 → EE2
- **Attack scenario:** User-controlled recovery questions or profile-related text are constructed to resemble trusted instructions or application-provided context. The LLM incorrectly interprets attacker-controlled content as higher-priority instructions.
- **Impact:** Prompt injection, unintended disclosure, incorrect guidance, or manipulation of AI behavior.
- **Severity:** High
- **Likelihood:** High
- **Mitigation:** Maintain explicit separation between system instructions, approved context, and user input. Sanitize and delimit user-controlled content in P5. Never rely on the LLM to distinguish security authority by itself.
- **OWASP LLM Top 10 mapping:** LLM01 – Prompt Injection.

Threat 25 — Trusting AI Output for Profile Updates

- **Threat ID:** T25
- **Threat name:** AI-Driven Unauthorized Profile Modification
- **STRIDE category:** Elevation of Privilege / Tampering
- **Affected component/data flow:** P4/P5 → P1 → P3 → DS1
- **Attack scenario:** An attacker manipulates P4 into producing an instruction or structured response that appears to request a profile update. If P1 or P3 treats the AI output as an authorized update request, the attacker may modify account information without P2 approval.
- **Impact:** Unauthorized profile modification and possible account takeover.
- **Severity:** Critical
- **Likelihood:** Low to Medium
- **Mitigation:** P3 must accept profile changes only through its defined authorization path and must require recovery authorization from P2. P4/P5 output must never constitute

authorization. Do not allow AI-generated content to directly invoke profile-management operations.

- **OWASP LLM Top 10 mapping: LLM05 – Improper Output Handling, LLM06 – Excessive Agency.**